

MoveInsight: Herramienta para el análisis de patrones de movimiento y prevención de lesiones

Anexo IV. Plan de seguridad

Trabajo de Fin de Grado

Grado en Ingeniería Informática



Junio de 2026

Autor

Diego Gómez Terradillos

Tutora

Dña. Carolina Zato Domínguez

Índice de Contenidos

Índice de Contenidos	i
Índice de Tablas.....	i
Índice de Figuras	i
1 Introducción	1
2 Metodología y herramientas	3
3 Identificación y valoración de activos	5
4 Análisis de amenazas y vulnerabilidades.....	7
5 Valoración del riesgo	9
6 Salvaguardas y controles	11
6.1 Controles técnicos	11
6.2 Controles organizativos	14
6.3 Controles legales	14
7 Puntos críticos (determinantes o impuestos por ley)	15
8 Aspectos legales.....	16
9 Respuesta a incidentes y continuidad	18
10 Trazabilidad: de los requisitos a los controles	19
Glosario de términos.....	20

Índice de Tablas

Tabla 1. Identificación y valoración de activos.....	5
Tabla 2. Valoración del riesgo.....	9
Tabla 3. Trazabilidad de los requisitos de seguridad del Anexo I.....	19

Índice de Figuras

Figura 1. Conexión segura HTTPS	12
---------------------------------------	----

1 Introducción

MoveInsight es un sistema de análisis biomecánico que captura vídeo del usuario, estima su pose y evalúa la técnica de ejecución de la sentadilla. Un sistema de estas características maneja, de principio a fin, información personal sensible, por lo que la seguridad no puede tratarse como un añadido posterior, sino que debe planificarse de forma explícita. Este anexo recoge ese plan: identifica los activos que deben protegerse, fija la metodología con la que se gestionan los riesgos y describe las medidas de carácter técnico, organizativo y legal adoptadas para hacerles frente. El objetivo último es preservar las propiedades fundamentales de la información: su confidencialidad (que solo acceda a ella quien está autorizado), su integridad (que no se altere ni se corrompa) y su disponibilidad (que esté accesible cuando se necesita), con especial atención a la protección de los datos personales.

MoveInsight no procesa simples registros numéricos, sino grabaciones de vídeo de personas identificables, y lo hace en dos contextos distintos. El primero es la construcción del dataset de entrenamiento, para el que se graba a personas expresamente con el fin de etiquetar sus movimientos y entrenar los modelos. El segundo es el uso ordinario de la aplicación, en el que cada usuario se graba a sí mismo para obtener el análisis de su técnica. En ambos casos, el contenido va más allá de la mera imagen: al tratarse de movimiento corporal aplicado al entrenamiento físico, el vídeo puede revelar información sobre el estado físico, las capacidades o las limitaciones de la persona. Esa combinación sitúa el tratamiento dentro de las categorías especiales del artículo 9 del RGPD [RGPD], que agrupa los datos merecedores de una protección reforzada, entre ellos los relativos a la salud y los biométricos.

El alcance del plan abarca el conjunto de elementos cuyo compromiso tendría consecuencias para las personas o para el propio sistema. Se incluyen, por un lado, los activos de información de carácter personal como son: los datos de cuenta y de perfil de los usuarios, las grabaciones y el dataset derivado de ellas, y el modelo entrenado, que conserva de forma indirecta información del conjunto con el que se entrenó. Por otro lado, los activos técnicos que los sostienen: las credenciales y los secretos, la base de datos, el código fuente y la infraestructura de despliegue. Quedan así cubiertas tanto la dimensión de privacidad como la de seguridad técnica.

Por último, el plan no se realiza de forma aislada, sino teniendo presente los requisitos no funcionales de seguridad y privacidad ya definidos en el Anexo I (NFR-05, Seguridad, y NFR-06, Privacidad y protección de datos). Cada uno de esos requisitos se enlaza con los controles concretos que lo satisfacen en la tabla de trazabilidad del apartado final, de modo que pueda comprobarse que ninguna exigencia queda sin respuesta.

Las referencias citadas en este anexo, en formato [Autor, año], se recogen en la bibliografía de la memoria principal.

2 Metodología y herramientas

Para elaborar el plan se han combinado metodologías y catálogos de referencia ampliamente reconocidos:

Para el análisis y la gestión del riesgo se ha empleado Magerit v3 [Magerit], la metodología de análisis y gestión de riesgos de los sistemas de información de referencia en la Administración pública española. Magerit proporciona un procedimiento sistemático que parte de la identificación de los activos, continúa con la determinación de las amenazas que pueden afectarlos y concluye con la estimación del riesgo a partir de la probabilidad de que cada amenaza se materialice y del impacto que tendría. En este trabajo se ha aplicado en su modalidad cualitativa, es decir, el riesgo se expresa como el producto de la probabilidad por el impacto sobre una escala de niveles (alto, medio, bajo), por ser la más adecuada a la escala de un Trabajo de Fin de Grado, en el que no se dispone de datos históricos suficientes para una valoración cuantitativa fiable. Este análisis puede sistematizarse, de forma opcional, con la herramienta PILAR, que automatiza el método, y admite como alternativa equivalente de ámbito internacional la norma ISO/IEC 27005. Magerit es, en definitiva, el hilo conductor de los apartados 3, 4 y 5, dedicados respectivamente a la valoración de los activos, al análisis de las amenazas y a la valoración del riesgo.

Para la seguridad de la capa web y de aplicación se ha recurrido a OWASP [OWASP] (Open Worldwide Application Security Project), una comunidad de referencia internacional en seguridad del software, de la que se han utilizado dos recursos. El primero es el OWASP Top 10, un catálogo periódicamente actualizado que recoge las diez categorías de vulnerabilidades más críticas y frecuentes en las aplicaciones web, se ha empleado como lista de comprobación frente a la que contrastar el sistema durante el análisis de amenazas (apartado 4), de modo que el estudio no dependa solo del criterio del autor, sino que cubra los riesgos reconocidos por la industria. El segundo es el ASVS (Application Security Verification Standard), un estándar que enumera de forma estructurada los requisitos de seguridad verificables que una aplicación debería satisfacer, aquí actúa como referencia para comprobar que las salvaguardas técnicas adoptadas (apartado 6) responden a esos requisitos.

Por último, para el cumplimiento legal y la privacidad el plan se rige por la normativa vigente de protección de datos: el Reglamento General de Protección de Datos (Reglamento UE 2016/679, RGPD), de aplicación directa en toda la Unión Europea, y la Ley Orgánica 3/2018 [LOPDGDD], que lo adapta al ordenamiento español. Ambas normas fijan las obligaciones que debe cumplir el tratamiento de datos personales, estas son las siguientes: base de licitud, deber de información, derechos de los interesados y medidas de seguridad. Como apoyo se han tomado los criterios de la Agencia Española de Protección de Datos [AEPD], autoridad de control en la materia, determinantes para decidir si procede realizar una Evaluación de Impacto relativa a la Protección de Datos [EIPD]. Todo este marco se desarrolla en detalle en el apartado 8.

3 Identificación y valoración de activos

Antes de poder proteger un sistema es necesario saber qué se protege y cuánto importa cada elemento, ya que ni todos los activos tienen el mismo valor ni las consecuencias de su compromiso son igual de graves. Por eso, en este apartado se identifican los activos de MoveInsight y se valora, para cada uno, en qué grado debe preservarse su confidencialidad (C), su integridad (I) y su disponibilidad (D). La valoración es cualitativa, sobre una escala de Alta, Media o Baja, nivel de detalle suficiente para el alcance de este trabajo.

El fin de esta clasificación es doble. Por un lado, permite ordenar los activos según su criticidad, de modo que el esfuerzo de protección pueda concentrarse allí donde un fallo de seguridad tendría peores consecuencias. Por otro, constituye la base de los apartados siguientes.

Activo	Tipo	C	I	D	Observaciones
Grabaciones de personas (app y dataset)	Datos personales: categoría especial (art. 9)	Alta	Alta	Media	Vídeo de persona identificable; puede revelar el estado físico
Dataset de entrenamiento etiquetado	Dato personal derivado	Alta	Alta	Media	Conjunto de grabaciones más sus etiquetas
Datos de cuenta y perfil de usuario	Dato personal	Alta	Alta	Media	Correo, nombre, contraseña (hash bcrypt) y perfil: edad, peso, nivel y objetivo
Modelo de aprendizaje automático entrenado	Activo técnico / propiedad intelectual	Media	Alta	Media	Riesgo de inferencia sobre los datos de entrenamiento
Credenciales y secretos	Activo crítico	Alta	Alta	Media	Clave de firma JWT, credenciales de MariaDB y del servicio SMTP
Base de datos	Infraestructura de datos	Alta	Alta	Alta	MariaDB 11 (motor InnoDB)
Código fuente	Propiedad intelectual	Media	Alta	Media	Repositorio Git privado; licencia pendiente de definir
Infraestructura de despliegue	Infraestructura	Media	Alta	Alta	Servidor único de la USAL; Docker Compose y proxy Nginx

Tabla 1. Identificación y valoración de activos

Hay que tener en cuenta y tratar las grabaciones y el dataset derivado como una categoría especial, ya que estas se clasifican como datos del artículo 9 del RGPD. Si tras revisar el tratamiento se concluyera que las grabaciones no revelan datos de salud ni identifican unívocamente a la persona (dato biométrico), la clasificación podría rebajarse a dato personal ordinario, lo que debería justificarse explícitamente. En el estado actual del proyecto se asume la categoría especial por prudencia.

4 Análisis de amenazas y vulnerabilidades

Una vez identificados y valorados los activos, el siguiente paso consiste en determinar qué puede ir mal.

Conviene distinguir aquí dos conceptos complementarios: una amenaza es un evento potencial que, de producirse, dañaría a un activo, por ejemplo, un acceso no autorizado. Mientras que una vulnerabilidad es la debilidad concreta que ese evento aprovecharía para materializarse, por ejemplo, un control de acceso mal implementado. El análisis combina, por tanto, dos catálogos de referencia: el de amenazas de Magerit, organizado por activo, y el de vulnerabilidades web y de aplicación de OWASP, a ellos se añaden las amenazas propias de un sistema que graba vídeo y emplea inteligencia artificial. El resultado de este apartado es el insumo directo de la valoración del riesgo del apartado 5.

En cuanto a las amenazas por activo, la más grave es el acceso no autorizado y la consiguiente fuga de información, que afectaría especialmente a las grabaciones, al dataset y a la base de datos por contener datos de categoría especial. A ella se suman la alteración o destrucción de los datos, que comprometería su integridad y la fiabilidad de los análisis; la suplantación de identidad, mediante la cual un atacante podría hacerse pasar por un usuario legítimo para acceder a su información; los errores de configuración del entorno, frecuentes y a menudo origen de otras brechas; la indisponibilidad del servicio por fallo de la infraestructura, especialmente relevante al apoyarse el despliegue en un único servidor; y la exposición accidental de secretos, como claves o credenciales filtradas de forma inadvertida.

Desde la perspectiva de las vulnerabilidades web y de aplicación, siguiendo el OWASP Top 10, la de mayor relevancia para este sistema es el control de acceso roto, esto es, la posibilidad de acceder a grabaciones ajenas manipulando los identificadores de las peticiones; por su naturaleza, es la debilidad que más directamente amenaza la confidencialidad de los datos personales. Junto a ella se consideran los fallos de autenticación, la exposición de datos sensibles cuando viajan o se almacenan sin cifrar, la inyección y la validación de entrada deficiente, una mala gestión de los secretos o una configuración insegura y, por último, un registro y una monitorización insuficientes, que dificultarían detectar un incidente y reaccionar a tiempo.

Finalmente, el carácter del proyecto introduce amenazas específicas de la captura y de la inteligencia artificial que los catálogos generales no contemplan. La primera es un consentimiento mal documentado o que no pueda revocarse, lo que invalidaría la base legal del tratamiento. La segunda es la conservación indefinida de las grabaciones, contraria al principio de limitación del plazo de conservación. Y la tercera, más sutil, es la fuga de información del dataset a través del propio modelo entrenado: mediante técnicas de inferencia podría llegar a deducirse si los datos de una persona formaron parte del conjunto de entrenamiento, lo que convierte al modelo en un activo que también debe protegerse.

5 Valoración del riesgo

Tras identificar las amenazas y las vulnerabilidades, este apartado las traduce en una medida de riesgo que permita priorizarlas. El riesgo de cada escenario se estima de forma cualitativa como el producto de dos factores: la probabilidad de que la amenaza llegue a materializarse y el impacto o gravedad de las consecuencias en caso de que lo hiciera. Ambos se expresan en una escala de tres niveles y su combinación determina el nivel de riesgo resultante, que es el que fija la prioridad de actuación.

Para cada riesgo se indica, además, su tratamiento. De las cuatro estrategias habituales, estas son: asumir, evitar, transferir o mitigar. En este plan todos los riesgos se afrontan mitigándolos, esto es, reduciéndolos mediante controles concretos, ya que la sensibilidad de los datos tratados no aconseja aceptar ninguno sin medidas. La tabla siguiente recoge los riesgos principales identificados, su valoración y la línea de tratamiento prevista, que se desarrolla en detalle en el apartado 6.

Riesgo	Prob.	Impacto	Nivel	Tratamiento
Acceso o fuga de grabaciones (categoría especial)	Media	Alto	Alto	Mitigar (cifrado, control de acceso, minimización)
Exposición de secretos en la configuración	Media	Alto	Alto	Mitigar (gestión de secretos)
Consentimiento inválido o no revocable	Baja	Alto	Medio	Mitigar (gestión de consentimientos, apdos. 6 y 8)
Acceso no autorizado por relación o propiedad	Media	Medio	Medio	Mitigar (autorización por pertenencia)
Indisponibilidad de los datos	Baja	Medio	Medio	Mitigar (copias de seguridad)

Tabla 2. Valoración del riesgo

Del análisis se extraen varias conclusiones. En primer lugar, los dos riesgos de nivel alto como son: el acceso o fuga de las grabaciones y la exposición de secretos en la configuración, comparten un impacto alto unido a una probabilidad media, lo que los convierte en la prioridad del plan y justifica que reciban las salvaguardas más exigentes: cifrado, control de acceso, minimización y gestión de secretos. En segundo lugar, predomina un impacto alto o medio en casi todos los escenarios, reflejo directo de la sensibilidad de los datos tratados; de hecho, incluso amenazas de probabilidad baja, como

un consentimiento inválido, se elevan a un riesgo medio por la gravedad de sus consecuencias. Por último, ningún riesgo se asume sin más: todos se afrontan mediante mitigación, de manera que el riesgo residual, (el que permanece una vez aplicados los controles del apartado 6) se mantenga en niveles aceptables.

6 Salvavidas y controles

Las salvavidas son las medidas concretas con las que se tratan los riesgos identificados en el apartado anterior. El plan las organiza en tres niveles complementarios, estos son: técnicas, organizativas y legales, que se corresponden con las tres dimensiones desde las que puede protegerse el sistema: la tecnología que lo implementa, los procedimientos que rigen su uso y el marco normativo que lo regula. Los tres se detallan a continuación.

6.1 Controles técnicos

Los controles técnicos son las medidas implementadas en el propio software y en la infraestructura de despliegue. A continuación, se describen los principales, acompañados, cuando procede, del fragmento de código del backend que los materializa.

Autenticación y autorización. El acceso a la aplicación se controla mediante tokens JWT (JSON Web Token). Tras iniciar sesión, el usuario recibe un token de acceso de corta duración (una hora) con el que se autentican sus peticiones, y un token de refresco de larga duración (treinta días) que le permite renovar el anterior sin volver a introducir sus credenciales. Cada token va firmado con una clave secreta del servidor, de modo que no puede falsificarse ni alterarse:

```
def create_access_token(email: str) -> str:          # token de
acceso (1 h)
    expire = datetime.now(timezone.utc) +
timedelta(hours=settings.JWT_EXPIRE_HOURS)
    payload = {"sub": email, "exp": expire, "type": "access"}
    return jwt.encode(payload, settings.JWT_SECRET_KEY,
algorithm=settings.JWT_ALGORITHM)

def create_refresh_token(email: str) -> str:          # token de
refresco (30 d)
    expire = datetime.now(timezone.utc) +
timedelta(days=settings.JWT_REFRESH_EXPIRE_DAYS)
    payload = {"sub": email, "exp": expire, "type": "refresh"}
    return jwt.encode(payload, settings.JWT_SECRET_KEY,
algorithm=settings.JWT_ALGORITHM)
```

Almacenamiento seguro de contraseñas. Las contraseñas nunca se guardan en formato de texto: en el momento del registro se transforman mediante una función hash con el algoritmo bcrypt, y en la base de datos solo se conserva ese resumen irreversible. Al iniciar sesión se compara el hash de la contraseña introducida con el almacenado, sin necesidad de recuperar la original:

```

pwd_context = CryptContext(schemes=["bcrypt"], deprecated="auto")

def hash_password(password: str) -> str:      # se almacena el hash,
nunca la contraseña
    return pwd_context.hash(password)

def verify_password(plain: str, hashed: str) -> bool:
    return pwd_context.verify(plain, hashed)

```

Cifrado en tránsito. Toda la comunicación entre la aplicación y el servidor viaja cifrada sobre HTTPS/TLS (versiones 1.2 y 1.3), con un certificado emitido por Let's Encrypt y una redirección forzada de HTTP a HTTPS en el proxy Nginx, de manera que ninguna petición circule en claro. La Figura siguiente muestra el candado del navegador y la URL del servicio como evidencia de que el acceso se realiza efectivamente sobre HTTPS. Como medidas de refuerzo se contemplan la cabecera HSTS (que obliga al navegador a emplear siempre HTTPS) y el cifrado en reposo de las grabaciones a nivel de volumen o de sistema de ficheros.

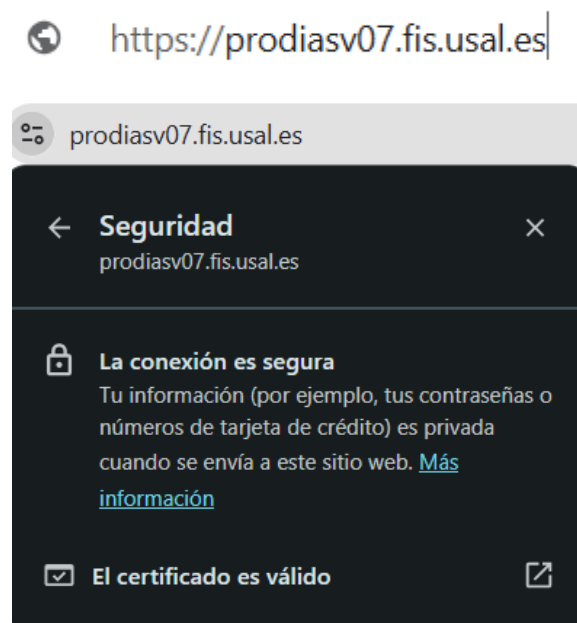


Figura 1. Conexión segura HTTPS

Control de acceso por propiedad. Cada grabación y cada registro pertenecen a un único usuario, y el sistema comprueba esa pertenencia antes de servir cualquier recurso. Las consultas filtran siempre por el identificador del usuario autenticado, de modo que manipular en la petición el identificador de una sesión ajena no permite acceder a ella: si el recurso no pertenece al solicitante, la respuesta es la misma que si no existiera (404).

Con ello se cierra la puerta a la vulnerabilidad de control de acceso roto señalada en el apartado 4:

```
# Solo se devuelve la sesión si pertenece al usuario autenticado
session = db.query(Session).filter(
    Session.id == session_id,
    Session.user_id == current_user.id,
).first()
if not session:
    raise HTTPException(status_code=404, detail="Sesión no encontrada")
```

Gestión de secretos fuera del código. Las credenciales sensibles como son: la clave de firma de los tokens, el acceso a la base de datos y la contraseña del servicio de correo, no se escriben en el código ni se suben al repositorio. Se cargan en tiempo de ejecución desde un fichero de entorno (.env) y variables de entorno que quedan fuera del control de versiones, lo que evita su exposición accidental:

```
class Settings(BaseSettings):
    DATABASE_URL: str # credenciales de la base de datos
    JWT_SECRET_KEY: str # clave de firma de los tokens
    EMAIL_PASSWORD: str = "" # contraseña del servicio SMTP

    class Config:
        env_file = BASE_DIR / ".env" # los valores se leen del
        .env, no del código
```

Aislamiento de la red. El despliegue se organiza de forma que solo el proxy inverso (Nginx) queda expuesto a Internet; la API y la base de datos permanecen en una red interna y no son accesibles directamente desde el exterior. Así, aunque se conozca su existencia, la base de datos no puede atacarse sin atravesar antes el proxy.

Minimización y seudonimización del dataset. La minimización es un principio de protección de datos según el cual solo deben tratarse los datos estrictamente necesarios para la finalidad perseguida, evitando recopilar o conservar información superflua; aplicado al dataset, significa quedarse únicamente con lo imprescindible para entrenar los modelos y no almacenar datos que no aporten valor al análisis. La seudonimización lo complementa separando la identidad de la persona del contenido de la grabación por ejemplo, sustituyendo su nombre por un código, de modo que, si el conjunto se viera comprometido, resulte mucho más difícil atribuir cada vídeo a una persona concreta.

Medidas de refuerzo previstas. Por último, el plan contempla varias medidas adicionales, aún no implementadas pero recomendables: la limitación de tasa (rate limiting) en los endpoints sensibles para frenar ataques de fuerza bruta, el registro y la

auditoría de los accesos a datos personales, y la realización de copias de seguridad periódicas con prueba de restauración.

6.2 Controles organizativos

Los controles organizativos no residen en el software, sino en los procedimientos y las normas que rigen cómo se usan los datos y quién puede acceder a ellos. Complementan a los técnicos, pues de poco sirve una medida tecnológica si el procedimiento que la rodea es débil.

Mínimo privilegio. El acceso a los datos y a los sistemas se concede conforme al principio de mínimo privilegio: cada actor dispone únicamente de los permisos imprescindibles para su función, y no más. Esto limita el alcance de un posible abuso o de unas credenciales comprometidas.

Gestión de consentimientos. Para las personas grabadas en la construcción del dataset se establece un procedimiento de consentimiento informado, explícito y granular: cada persona conoce con detalle el tratamiento al que accede y lo autoriza de forma expresa. Los consentimientos otorgados se registran y se habilita un procedimiento de revocación que, al ejercerse, conlleva la supresión efectiva de las grabaciones afectadas.

6.3 Controles legales

Los controles legales garantizan que el tratamiento se ajuste a la normativa de protección de datos. Los principales son la existencia de una base de licitud válida el consentimiento explícito de los interesados, el cumplimiento del deber de información, la garantía de los derechos de los interesados (en especial el de supresión de las grabaciones) y, dada la sensibilidad de los datos, la valoración de una Evaluación de Impacto (EIPD). Por su entidad y su carácter determinante, estos controles se desarrollan de forma detallada en el apartado 8.

7 Puntos críticos (determinantes o impuestos por ley)

A diferencia del apartado 6, que recoge el conjunto de salvaguardas del sistema, este apartado destaca los pocos puntos que no admiten omisión: los que vienen impuestos directamente por la legislación o los que resultan determinantes para la viabilidad del proyecto. No vuelven a explicarse aquí los mecanismos, sino que se subraya por qué cada uno es crítico. Se presentan por orden de criticidad.

1. Tratamiento de categorías especiales de datos. Es el punto del que depende todo lo demás. Como el sistema maneja vídeo de personas del que puede inferirse su estado físico, el artículo 9 del RGPD impone una base de licitud reforzada, el consentimiento explícito y medidas de seguridad acordes con esa sensibilidad. No es una opción de diseño, sino una obligación legal que condiciona tanto los controles del apartado 6 como el desarrollo jurídico del apartado 8.

2. Consentimiento y derecho a la propia imagen. Estrechamente ligado al anterior, afecta a las personas grabadas para construir el dataset. Además del RGPD, entra en juego la Ley Orgánica 1/1982 [LO 1/1982]: no basta con una cesión genérica de la imagen, sino que se exige un consentimiento informado, documentado y revocable, específico para esta finalidad. Sin él, la construcción del dataset carecería de cobertura legal y no podría llevarse a cabo.

3. Almacenamiento y cifrado de las grabaciones y del dataset. Es crítico porque sobre estos datos recae el riesgo más grave identificado en el apartado 5. Su protección se materializa en los controles técnicos del apartado 6, y un fallo aquí comprometería directamente datos de categoría especial.

4. Gestión de secretos y credenciales. La filtración de una sola credencial (la clave de firma de los tokens, el acceso a la base de datos) bastaría para anular el resto de las defensas; de ahí que su custodia fuera del código, descrita en el apartado 6, se considere un punto determinante y no una buena práctica más.

5. Control de acceso por pertenencia o propiedad. Garantiza que cada usuario acceda únicamente a sus propios datos. Es crítico porque ataja la vulnerabilidad más probable y directa contra la confidencialidad —el acceso a grabaciones ajenas—, y su implementación concreta se detalla en el apartado 6.

8 Aspectos legales

Este apartado desarrolla el marco jurídico que regula el tratamiento, anticipado en los puntos críticos y exigido por el requisito NFR-06 del Anexo I. Dada la naturaleza de los datos, su cumplimiento no es accesorio, sino una condición para la puesta en marcha del sistema.

RGPD y LOPDGDD. El tratamiento, por ser de categoría especial, requiere una base de licitud específica. Para el uso de la aplicación, esa base es el consentimiento explícito del usuario (art. 9.2.a). Para la construcción del dataset puede ampararse, además, en el régimen de investigación científica (art. 9.2.j del RGPD, junto con el art. 89 y la disposición adicional 17.^a de la LOPDGDD), siempre que se adopten las garantías adecuadas. A ello se suman el deber de información a los interesados (art. 13) y la garantía de sus derechos como son el derecho de acceso, rectificación, supresión, oposición, etc. (arts. 15 a 22), entre los que cobra especial relevancia el de supresión, que se traduce en el borrado efectivo de las grabaciones.

Evaluación de Impacto (EIPD). El artículo 35 obliga a realizar una evaluación de impacto cuando un tratamiento entraña un riesgo elevado para los derechos de las personas. Aquí concurren tres factores que lo elevan: categorías especiales, un tratamiento a cierta escala y el uso de tecnología innovadora (IA y vídeo), por lo que, conforme a los criterios de la AEPD, procede valorarla y, previsiblemente, realizarla. Del análisis preliminar se concluye que debería completarse antes de un despliegue con usuarios reales.

Roles RGPD. Deben definirse el responsable del tratamiento y, en su caso, los encargados (art. 28). Si la captura se realiza en el marco de la USAL, el responsable es, previsiblemente, la Universidad. El único servicio de terceros empleado es el proveedor de correo SMTP (Gmail), utilizado para enviar los códigos de verificación y de restablecimiento de contraseña; respecto a él debe formalizarse el encargo de tratamiento y valorarse la posible transferencia internacional asociada. El resto del procesamiento y del almacenamiento reside en el servidor de la USAL.

Reglamento de IA (UE 2024/1689) [Reglamento IA]. Procede valorar y justificar la categoría de riesgo del sistema. Si este analiza el movimiento sin identificar unívocamente a la persona ni deducir características protegidas, lo previsible es un riesgo limitado o mínimo. Las obligaciones de transparencia (art. 50) son exigibles desde agosto

de 2026 y las de alto riesgo para biometría desde finales de 2027; como apoyo existen las guías en español de la AESIA.

Propiedad intelectual. La licencia del código y la titularidad del dataset se fijarán antes de cualquier difusión.

9 Respuesta a incidentes y continuidad

Ninguna medida preventiva elimina por completo la posibilidad de un incidente; por ello, el plan no solo trata de evitarlos, sino que prevé cómo detectarlos, notificarlos y recuperar la normalidad si llegan a producirse.

Brechas de seguridad. Se establece un procedimiento de detección y notificación conforme al RGPD: la comunicación a la AEPD en un plazo máximo de 72 horas desde que se tiene constancia de la brecha (art. 33) y, cuando esta entrañe un alto riesgo para los afectados, también la comunicación a estos (art. 34).

Continuidad del servicio. La continuidad se apoya en copias de seguridad periódicas de la base de datos y de las grabaciones, acompañadas de una prueba de restauración que confirme que son recuperables. Además, la API se ejecuta sin modo de depuración, de modo que, ante un error, no se exponen al cliente trazas ni información interna del sistema que pudieran facilitar un ataque.

Revocación del consentimiento. Como contrapartida del consentimiento, se garantiza un flujo de revocación que asegura la supresión efectiva de las grabaciones de quien decide retirarlo, en coherencia con el derecho de supresión recogido en el apartado anterior.

10 Trazabilidad: de los requisitos a los controles

La validez de un plan de seguridad no se mide por la cantidad de controles que enumera, sino por su capacidad de dar respuesta a las necesidades concretas que el sistema se había planteado. Por eso, este apartado cierra el anexo estableciendo la trazabilidad entre los requisitos de seguridad y privacidad definidos en el Anexo I y los controles desplegados a lo largo de este documento.

Su función es doble: por un lado, demostrar que ninguno de esos requisitos ha quedado sin respuesta; por otro, permitir el camino inverso: dado un control, identificar qué exigencia lo justifica, lo que dota al plan de un carácter verificable y no simplemente teórico. La tabla siguiente recoge ese enlace.

Requisito (Anexo I)	Control en este anexo
NFR-05 Seguridad	Autenticación JWT y hash bcrypt, control de acceso por pertenencia, TLS/HTTPS y gestión de secretos (apdos. 6 y 7)
NFR-06 Privacidad y protección de datos	Consentimiento, minimización y supresión; base de licitud y derechos RGPD (apdos. 6 y 8)
CRQ-03 Aislamiento por usuario	Comprobación de propiedad: cada consulta filtra por el identificador del usuario; cada cual accede solo a sus propios datos (apdos. 6 y 7)
CRQ-09 Validación de contraseñas	Requisitos de complejidad y almacenamiento como hash bcrypt (apdo. 6)
CRQ-07 Formato y tamaño del vídeo	Validación de la entrada y límite de tamaño en Nginx (client_max_body_size 200M) (apdo. 6)

Tabla 3. Trazabilidad de los requisitos de seguridad del Anexo I

De la tabla se extraen dos conclusiones. La primera es de completitud: todos los requisitos de seguridad y privacidad establecidos en el Anexo I cuentan con al menos un control que los satisface, de modo que no queda ninguna exigencia desatendida. La segunda es de solidez: varios requisitos no se cubren con una única medida, sino con la combinación de varias, NFR-05, por ejemplo, se apoya a la vez en la autenticación, el control de acceso, el cifrado y la gestión de secretos, lo que refleja un enfoque de defensa en profundidad en el que la protección no descansa en un solo punto.

En conjunto, la trazabilidad confirma que el plan no es un catálogo genérico de buenas prácticas, sino una respuesta directa y comprobable a los requisitos que el propio sistema se había fijado.

Glosario de términos

Se recogen a continuación los términos técnicos y específicos del dominio empleados a lo largo de este anexo, con el fin de facilitar su comprensión.

- **AEPD (Agencia Española de Protección de Datos).** Autoridad de control española en materia de protección de datos; sus criterios orientan, entre otras decisiones, la realización de la Evaluación de Impacto.
- **AESIA (Agencia Española de Supervisión de la Inteligencia Artificial).** Organismo encargado de la supervisión del Reglamento de IA en España; publica guías de apoyo en español.
- **ASVS (Application Security Verification Standard).** Estándar de OWASP que enumera requisitos de verificación de seguridad para aplicaciones web.
- **Base de licitud.** Fundamento jurídico que legitima un tratamiento de datos personales según el RGPD (por ejemplo, el consentimiento explícito).
- **bcrypt.** Función de derivación de clave empleada para almacenar las contraseñas como hash, resistente a ataques de fuerza bruta.
- **Brecha de seguridad.** Violación de la seguridad que ocasiona la destrucción, pérdida, alteración o acceso no autorizado a datos personales; obliga a notificar a la AEPD en 72 horas.
- **Categoría especial (art. 9 del RGPD).** Datos especialmente protegidos (de salud, biométricos, etc.) cuyo tratamiento exige garantías reforzadas y una base de licitud específica.
- **Cifrado en reposo.** Cifrado de los datos mientras permanecen almacenados, de modo que no sean legibles sin la clave aunque se acceda al soporte.
- **Cifrado en tránsito.** Cifrado de los datos mientras viajan por la red, proporcionado aquí por TLS/HTTPS.
- **Confidencialidad, integridad y disponibilidad (CID).** Las tres propiedades básicas de la seguridad de la información sobre las que se valora cada activo.
- **Consentimiento informado.** Manifestación libre, específica, informada e inequívoca por la que el interesado acepta el tratamiento de sus datos; ha de ser explícito para las categorías especiales.
- **Dato biométrico.** Dato obtenido a partir de las características físicas o de comportamiento de una persona que permite su identificación unívoca.

- **Dato de salud.** Dato relativo al estado físico o mental de una persona; pertenece a las categorías especiales del artículo 9.
- **Derecho a la propia imagen.** Derecho fundamental (LO 1/1982) que protege el control de la persona sobre la captación y el uso de su imagen.
- **EIPD (Evaluación de Impacto relativa a la Protección de Datos).** Análisis previo de los riesgos de un tratamiento para los derechos de los interesados, exigible (art. 35) cuando el riesgo es elevado.
- **Encargado del tratamiento.** Persona o entidad que trata datos personales por cuenta del responsable, regulada por el artículo 28 del RGPD.
- **ENS (Esquema Nacional de Seguridad).** Marco español de seguridad de obligado cumplimiento para los sistemas de información del sector público.
- **HSTS (HTTP Strict Transport Security).** Cabecera que obliga al navegador a comunicarse siempre mediante HTTPS, evitando conexiones en claro.
- **JWT (JSON Web Token).** Token firmado que transporta la identidad del usuario y permite autenticar las peticiones sin mantener estado en el servidor.
- **LOPDGDD.** Ley Orgánica 3/2018 de Protección de Datos Personales y garantía de los derechos digitales, que adapta el RGPD al ordenamiento español.
- **Magerit.** Metodología de análisis y gestión de riesgos de los sistemas de información elaborada por el CCN.
- **Minimización de datos.** Principio del RGPD por el que solo se tratan los datos estrictamente necesarios para la finalidad perseguida.
- **OWASP (Open Worldwide Application Security Project).** Comunidad de referencia en seguridad de aplicaciones; su Top 10 recopila las vulnerabilidades web más críticas.
- **PILAR.** Herramienta de soporte al análisis de riesgos conforme a la metodología Magerit.
- **Rate limiting.** Limitación del número de peticiones admitidas en un periodo, empleada para frenar abusos y ataques de fuerza bruta.
- **Reglamento de IA (UE 2024/1689).** Reglamento europeo que clasifica los sistemas de inteligencia artificial por nivel de riesgo y fija sus obligaciones.
- **Responsable del tratamiento.** Persona o entidad que decide los fines y los medios del tratamiento de datos personales.
- **RGPD.** Reglamento General de Protección de Datos (UE 2016/679), norma europea de referencia en protección de datos personales.

- **Seudonimización.** Tratamiento de los datos de modo que no puedan atribuirse a una persona sin información adicional conservada por separado.
- **TLS / HTTPS.** Protocolo que cifra la comunicación en la red; HTTPS es HTTP sobre TLS.
- **Transferencia internacional.** Comunicación de datos personales a un país u organización fuera del Espacio Económico Europeo, sujeta a garantías específicas.